

【中间件安全】Jboss安全加固规范 - 微信公众号Bypass

1. 适用情况

适用于使用Jboss进行部署的Web网站。

适用版本：5.x版本的Jboss服务器

2. 技能要求

熟悉Jboss安装配置，能够Jboss进行部署，并能针对站点使用Jboss进行安全加固。

3. 前置条件

根据站点开放端口，进程ID，确认站点采用Nginx进行部署；

找到Jboss安装目录，针对具体站点对配置文件进行修改；

在执行过程中若有任何疑问或建议，应及时反馈。

4. 详细操作

4.1 日志配置

Jboss 5.x版本日志配置：

1、打开%JBOSS_HOME%\server\default\deployers\jbossweb.deployer\server.xml文件，在<HOST>标签中，将Access logger以下内容的注释标记取消，取消后的内容如下：

```
<Host name="localhost"
  autoDeploy="false" deployOnStartup="false" deployer="false"
  configClass="org.jboss.web.tomcat.security.ConfigurableTomcatConfig"
  >
  <!-- Uncomment to enable request dumps. This value "logs interesting
  <!-- output from the specified Request (before processing) and the
  <!-- corresponding Response (after processing). It is especially useful
  <!-- in debugging problems related to headers and cookies."
  <!--
  <val>
  <val>false</val>
  </val>
  <!-- Access Logger -->
  <val>false</val>
  <val>org.apache.catalina.valves.AccessLogValve</val>
  <val>pattern="localhost_access_log.%d.%m.%y.log"</val>
  <val>pattern="common"</val>
  <val>digest="md5"</val>
  <val>format="true"</val>
  </val>
```

2、重启Jboss服务，网站访问日志生成在JBOSS_HOME%\server\default\log目录下。

Jboss7日志配置：

1、在默认的情况下，JBoss7是没有开启access_log的，如果要开启这项功能，就需要修改\$JBOSS_HOME\standalone\configuration\standalone.xml这个文件，备份配置文件，相关的修改内容如下所示：

```
<virtual-server name="default-host" enable-welcome-root="true">
```

```
<alias name="localhost"/>
```

```
<alias name="example.com"/>
```

```
<access-log pattern="%t %a %m %U %s %D" prefix="access_log." rotate="true">
```

```
<directory path="." relative-to="jboss.server.log.dir"/>
```

```
</access-log>
```

```
</virtual-server>
```

重启即可看到\${jbossHome}\standalone\log\目录下生成access_log

4.2 错误页面重定向

1、找到%JBOSS_HOME%\server\default\deployers\jbossweb.deployer\conf\web.xml文件，对该文件内容进行编辑：

```
<welcome-file-list>
```

```
<welcome-file>index.html</welcome-file>
```

```
<welcome-file>index.htm</welcome-file>
```

```
<welcome-file>index.jsp</welcome-file>
```

```
</welcome-file-list>
```

2、重新启动 Jboss 服务

4.3 最佳操作实践

4.3.1 关闭jmx-console

1、找到%JBOSS_HOME%\server\default\deploy\jmx-console.war\WEB-INF\jboss-web.xml文件，去掉下面这段xml文本的注释。修改后的该文件内容为：

```
<!DOCTYPE jboss-web PUBLIC
    "-//JBoss//DTD Web Application 5.0//EN"
    "http://www.jboss.org/j2ee/dtd/jboss-web_5_0.dtd">

<jboss-web>
  <!-- Uncomment the security-domain to enable security. You will
       need to edit the htmladaptor login configuration to setup the
       login modules used to authentication users.
  -->
  <security-domain>java:/jaas/jmx-console</security-domain>
</jboss-web>
```

2、与jboss-web.xml同级目录下还有一个文件web.xml，，查找到<security-constraint/>节点，去掉它的注释，修改后该部分内容为：

```
<!-- A security constraint that restricts access to the HTML JMX console
to users with the role JBossAdmin. Edit the roles to what you want and
uncomment the WEB-INF/jboss-web.xml/security-domain element to enable
secured access to the HTML JMX console. -->
<security-constraint>
  <web-resource-collection>
    <web-resource-name>HtmlAdapter</web-resource-name>
    <description>An example security config that only allows users with the
    role JBossAdmin to access the HTML JMX console web application
    </description>
    <url-pattern>/*</url-pattern>
    <http-method>GET</http-method>
    <http-method>POST</http-method>
  </web-resource-collection>
  <auth-constraint>
    <role-name>JBossAdmin</role-name>
  </auth-constraint>
</security-constraint>
```

3、在%Jboss_HOME%\server\default\conf\props\jmx-console-users.properties, 该文件定义的格式为：用户名=密码，在该文件中，默认定义了一个用户名为admin，密码也为admin的用户，建议设置强口令密码。

在同目录下jmx-console-roles.properties, 该文件定义的格式为：用户名=角色，多个角色以“,” 隔开，该文件默认为admin用户定义了JBossAdmin和HttpInvoker这两个角色。

可以找到这两个文件，修改用户名和密码。

4、配置完成，通过访问：http://localhost:8088/jmx-console/，输入jmx-console-roles.properties文件中定义的用户名和密码，访问jmx-console的页面。

4.3.2 关闭web-console

1、找到%JBOSS_HOME%\server\default\deploy\management\console-mgr.sar\web-console.war\WEB-INF\jboss-web.xml文件，去掉<security-domain>节点的注释，修改后的文件内容为：

```
<?xml version='1.0' encoding='UTF-8' ?>

<!DOCTYPE jboss-web
PUBLIC "-//JBoss//DTD Web Application 2.3V2//EN"
"http://www.jboss.org/j2ee/dtd/jboss-web_2_2.dtd">

<jboss-web>

  <!-- Uncomment the security-domain to enable security. You will
  need to edit the htmladapter login configuration to setup the
  login modules used to authentication users. -->
  <security-domain>java:/jaas/web-console</security-domain>

  <!-- The war depends on the -->
  <depends>jboss.admin:service=PluginManager</depends>
</jboss-web>
```

2、与jboss-web.xml同级目录下还有一个文件web.xml，查找到<security-constraint/>节点，去掉它的注释，修改后该部分内容为：

```
<!-- A security constraint that restricts access to the HTML JMX console
to users with the role JBossAdmin. Edit the roles to what you want and
uncomment the WEB-INF/jboss-web.xml/security-domain element to enable
secured access to the HTML JMX console. -->

<security-constraint>
  <web-resource-collection>
    <web-resource-name>HtmlAdapter</web-resource-name>
    <description>An example security config that only allows users with the
    role JBossAdmin to access the HTML JMX console web application
    </description>
    <url-pattern>/*</url-pattern>
    <http-method>GET</http-method>
    <http-method>POST</http-method>
  </web-resource-collection>
  <auth-constraint>
    <role-name>JBossAdmin</role-name>
  </auth-constraint>
</security-constraint>
```

3、打开%Jboss_HOME%\server\default\deploy\management\console-mgr.sar\web-console.war\WEB-INF\classes\web-console-users.properties, 设置用户名、密码。

```
# A sample users.properties file for use with the UsersRolesLoginModule
admin=admin
```

要分配一个用户到JBossAdmin组里，在同目录下的web-console-roles.properties.properties文件里添加"username=JBossAdmin"

```
# A sample roles.properties file for use with the UsersRolesLoginModule
admin=JBossAdmin
```

两个文件默认是admin/admin的用户，为了安全起见，建议更换一个强口令密码。

4.3.3 关闭status统计信息

1、打开%JBOSS_HOME%\server\default\deploy\ROOT.war\WEB-INF\web.xml，将以下部分注释掉：

```
<servlet>

    <servlet-name>Status Servlet</servlet-name>

    <servlet-class>org.jboss.web.tomcat.service.StatusServlet</servlet-class>

</servlet>

<servlet-mapping>

    <servlet-name>Status Servlet</servlet-name>

    <url-pattern>/status</url-pattern>

</servlet-mapping>
```

2、重新启动 Jboss 服务

4.3.4 删除默认文件

如果不需要使用后台页面，找到jboss部署目录，将 %JBOSS_HOME%\server\default\deploy\ROOT.war文件夹下的所有文件备份到其它位置后删除文件夹下的所有文件。

4.3.5 禁止目录列出

1、找到%JBOSS_HOME%\server\default\deployers\jbossweb.deployer\conf\web.xml文件，对该文件内容进行编辑：

```
<init-param>

    <param-name>listings</param-name>

    <param-value>>false</param-value>

</init-param>
```

把 true 改成 false

2、重新启动 Jboss 服务

4.3.6 定时登出

1、找到%JBOSS_HOME%\server\default\deployers\jbossweb.deployer\server.xml文件，修改为1800秒，30分钟自动登出：

```
<Connector protocol="HTTP/1.1" port="8080" address="{jboss.bind.0.0.0.0}"
connectionTimeout="1800" redirectPort="8443" />
```

2、重新启动 Jboss 服务

4.4 风险操作项

4.4.1 Jboss降权

建议配置 linux 系统：

- (1) 创建 jboss 组：groupadd Jboss
- (2) 创建 jboss 用户并加入 jboss 组：useradd Jboss -g Jboss
- (3) 以 Jboss 身份启动服务

Windows 系统：

- (1) 新建一个 Jboss 用户
- (2) 设置 Jboss 用户对 Jboss_home 的相关权限
- (3) 在服务管理器 (service.msc) 中找到 Jboss 服务，右键选择属性，设置登录身份为 Jboss 用户

4.4.2 更改默认端口

1、打开%JBOSS_HOME%\server\default\deployers\jbossweb.deployer\server.xml文件，备份配置文件，改默认端口到8100：

```
<Connector port="8100" address="{jboss.bind.address}"
maxThreads="250" strategy="ms" maxHttpHeaderSize="8192"
emptySessionPath="true"
enableLookups="false" redirectPort="8443" acceptCount="100"
connectionTimeout="1800"
disableUploadTimeout="true" URIEncoding="utf-8"/>
```

2、重新启动 Jboss 服务

最后

欢迎关注个人微信公众号：Bypass--，每周原创一篇技术干货。



posted @ 2018-12-24 10:23 [Bypass](#) 阅读(...) 评论(...) [编辑](#) [收藏](#)